

Design Specification for Internet Hosting Service in Google Cloud

Approval

Completion of the following signature blocks signifies that authors and approvers have been trained on the related process, have read, understood, and agree with the content of this document.

Name	Job Title and Role	Signature	Date (dd-mmm-yyyy)
The author (a Developer) is signing to confirm that this document has been prepared in accordance with an approved document management process, that content is consistent with the deliverable definition found in <i>Specify System</i> , SOP-IT-0032 [1], that relevant input from any contributory authors has been included and that an appropriate review / editing process has been conducted.			
Authored by: Jaroslaw Wencel	Author	refer to VQD	refer to VQD
The Developer (selected by the Project Manager as responsible for the design of the system) is signing to confirm that the Design Specification is fit for purpose, that it will deliver a computer system that satisfies the System Requirements and that it will be used for the development or configuration of the computer system			
Approved by: Steve McConnell	Developer	refer to VQD	refer to VQD

TABLE OF CONTENTST

1. INTRODUCTION	3
1.1 Definitions	3
2. DESIGN SPECIFICATION	4
2.1 Infrastructure	4
2.1.1 Internet Hosting Shared VPC & projects structure for non-production BioPharm	5
2.1.2 Internet Hosting Shared VPC & projects structure for production BioPharm	6
2.1.3 Internet Hosting Shared VPC & projects structure for non-production CH	Error! Bookmark not defined.
2.1.4 Internet Hosting Shared VPC & projects structure for production CH	Error! Bookmark not defined.
2.2 Architecture components	7
2.2.1 Virtual Private Cloud	7
2.2.2 Projects breakdown & shared VPCs	9
2.2.3 Compute VM / Instance group	10
2.2.4 Cloud Load Balancing & Cloud Armor	11
2.2.5 Cloud Functions & Cloud Run	12
2.2.6 Logging & Monitoring	12
2.2.7 Cloud SQL	13
2.2.8 NetApp	13
2.2.9 VPNs / Routing / internet access via Cloud NAT	14
2.2.10 Standard firewall configuration	15
2.2.11 Identity Aware Proxy	15
2.2.12 Security Command Center	16
2.3 Software stacks	16
2.3.1 Root modules	16
2.3.2 Workload modules	17
2.3.3 Config modules	17
2.3.4 Stateless-managed hosting stack	18
2.3.5 Stateful-unmanaged hosting stack	19
2.3.6 CI/CD & stack management components	21
2.4 Data	21
2.5 System Operation Specification	21
2.6 Specific Areas of Design	21
2.6.1 Access Management	21
2.6.2 System Security and Information Protection	22
2.6.3 Password management	22
2.6.4 Audit Trail & logging strategy	22
2.6.5 Electronic Signatures	23
2.6.6 Resilience and Continuity	23
2.6.7 Network Security & segmentation	23
2.6.8 Host System Security and Threat and Vulnerability Management	24
2.6.9 SSL Certificates management	24
2.6.10 Encryption at-rest	25
2.6.11 Other Risk-related Design Component	25
2.7 Configuration management approach	25
2.8 User Interface	26
3. REFERENCES	26
4. REVISION HISTORY	27

1. Introduction

This document contains the Design Specification for Internet Hosting Environment in Google Cloud. It provides the details required for an implementation to satisfy the Business Requirements in the URS and to provide a fit-for-purpose system.

System Identifier	Internet Hosting and Platform Support / S079777852
System Name	Internet Hosting Environment in Google Cloud
Relevant Requirements Specifications	System Requirements for Internet Hosting in GCP [2]
Vendor Specifications	Google Cloud Platform
Design Methodology	Re-use of existing modules delivered by Cloud Enablement team
Architectural Controls	N/A

1.1 Definitions

Table 1 - Definitions

Term	Definition
GCP	Google Cloud Platform
IH or IHS	Internet Hosting Service
Dreamforce/Cloud Enablement	cross functional product, design and engineering team within Pharma Tech responsible for hosting GSK's products in Google Cloud Platform (GCP), this team initially designed cloudpharma.tech organization setup and passed it over to IHS Team
IAP	Identity Aware Proxy
GKE	Google's Kubernetes Engine
SCC	Security Command Centre, Google's console showing results of periodic security scan
IP&P	Intrusion Protection & Prevention

2. Design Specification

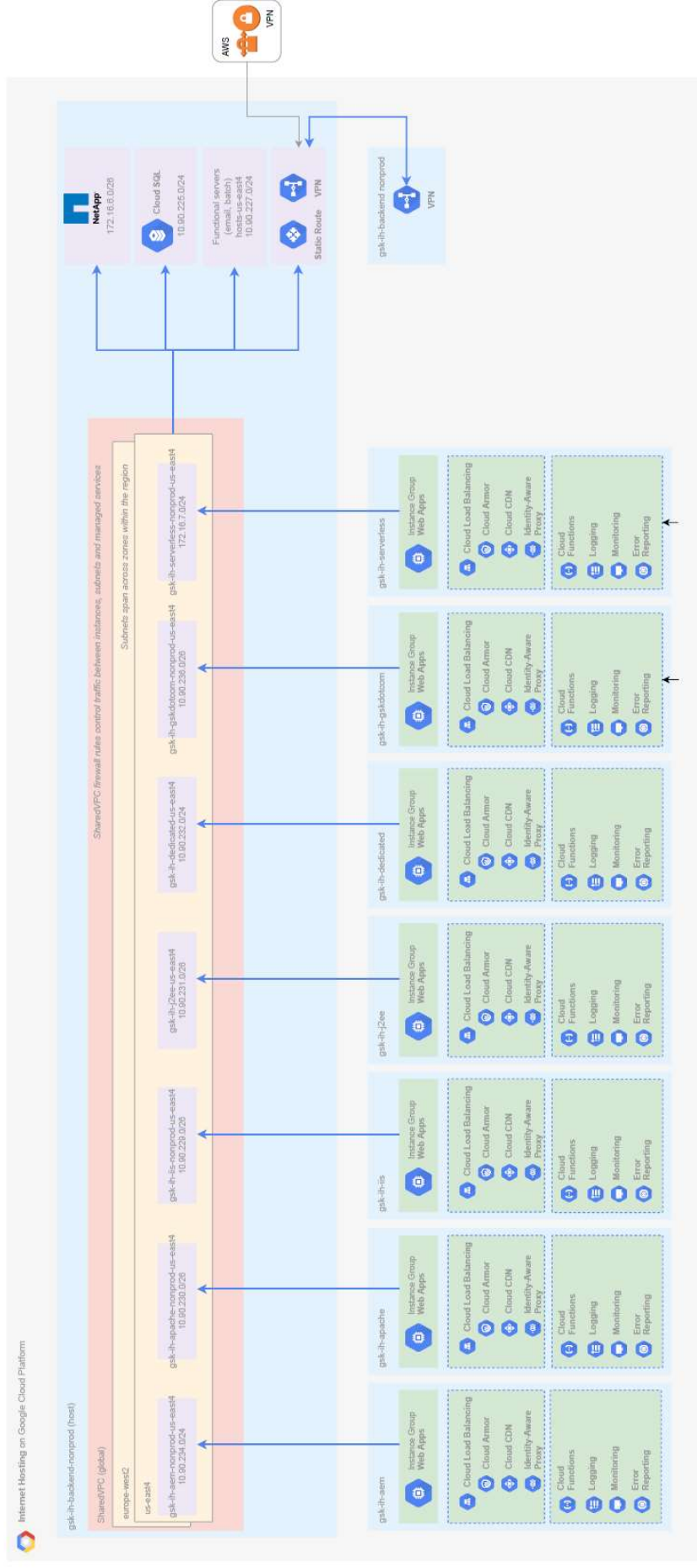
Internet Hosting Environment in Google Cloud is based on cloud-native design approach where whole environment starting from Infrastructure through configuration and finishing on applications is managed as-a-code. The above means that environment configuration is described within machine-readable files (Terraform code) and any change in configuration does not require any hardware-related physical activities.

2.1 Infrastructure

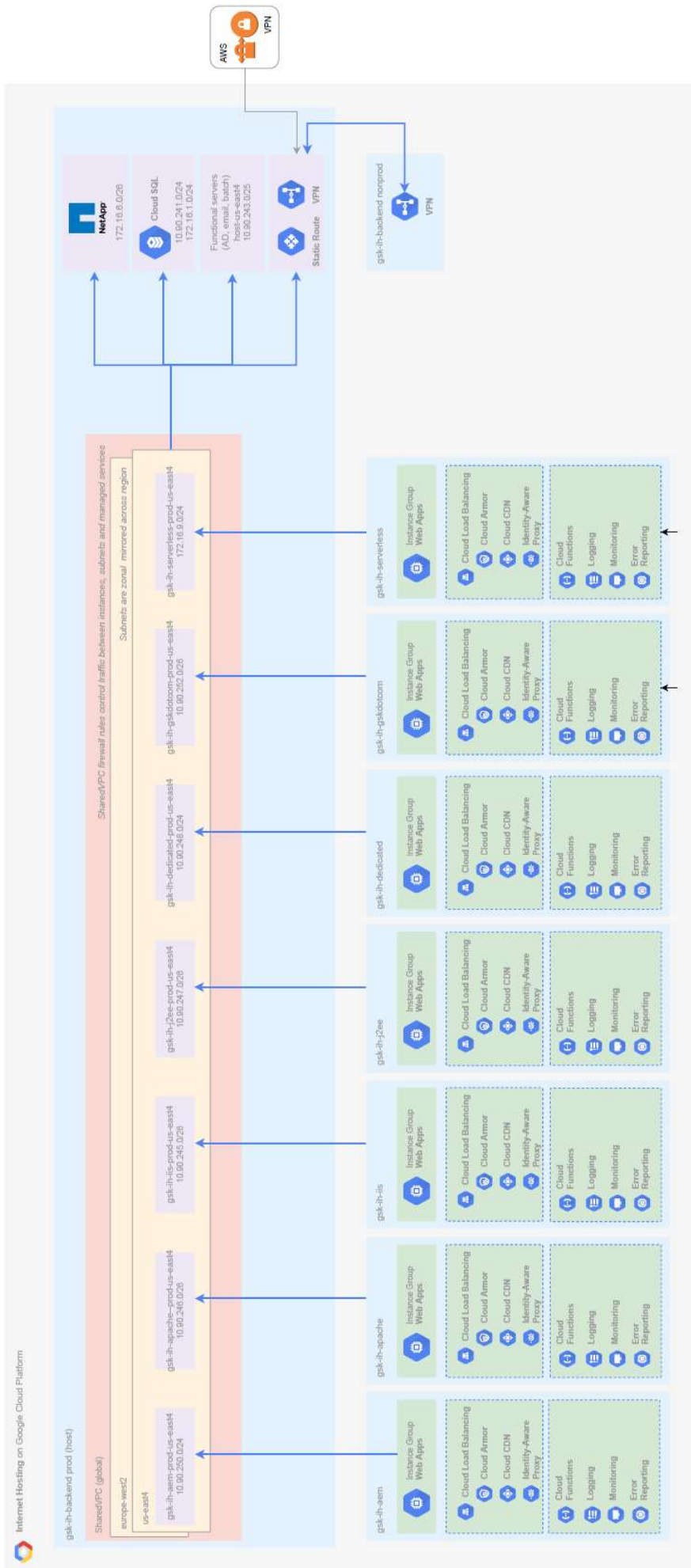
The infrastructure for Internet Hosting Environment in Google Cloud is delivered in Infrastructure-as-a-Service model.

The infrastructure design is depicted in following sections:

2.1.1 Internet Hosting Shared VPC & projects structure for non-production BioPharm



2.1.2 Internet Hosting Shared VPC & projects structure for production BioPharm



2.2 Architecture components

2.2.1 Virtual Private Cloud

Virtual Private Cloud or simply VPC is the most basic term within whole Google Cloud architecture [3].

VPC network must be understood as equal to a physical network, except that it is virtualized within Google Cloud. A VPC network is a global resource that consists of a list of regional virtual subnetworks (subnets) in data centre, all connected by a global wide area network. VPC networks are logically isolated from each other in Google Cloud.

Further division of regions are zones – each region within GCP has at least 3 zones which are physically independent from each other. The zones shall be understood as different computer room within one location, where the resources can be provisioned within various zones for redundancy [4].

2.2.1.1 GSK-assigned networking ranges

The following ranges are assigned by GSK's networking team for the Internet Hosting's GCP workloads. The IP range does not overlap with any ranges in GSK.

10.90.224.0/19 - this is the full range which is split in two as follows:

10.90.224.0/20 - allocated for non-production workloads

10.90.240.0/20 - allocated for production workloads

Backend services (gcp-ih-backend)		
Environment	Region	CIDR
Nonprod	us-east4	10.90.227.0/25
	europe-west2	10.90.227.128/25
	netapp	10.90.228.0/24
	cloudsql	10.90.225.0/24 10.90.226.0/24
Prod	us-east4	10.90.243.0/25
	europe-west2	10.90.243.128/25
	netapp	10.90.244.0/24
	cloudsql	10.90.241.0/24 10.90.242.0/24
IIS (gcp-ih-iis)		
Environment	Region	CIDR
Nonprod	us-east4	10.90.229.0/26
	FREE	10.90.229.64/26
	europe-west2	10.90.229.128/26
	FREE	10.90.229.192/26
Prod	us-east4	10.90.245.0/26
	FREE	10.90.245.64/26
	europe-west2	10.90.245.128/26
	FREE	10.90.245.192/26
Apache (gcp-ih-apache)		
Environment	Region	CIDR
Nonprod	us-east4	10.90.230.0/26
	FREE	10.90.230.64/26
	europe-west2	10.90.230.128/26
	FREE	10.90.230.192/26
Prod	us-east4	10.90.246.0/26
	FREE	10.90.246.64/26
	europe-west2	10.90.246.128/26
	FREE	10.90.246.192/26
J2EE (gcp-ih-j2ee)		
Environment	Region	CIDR
Nonprod	us-east4	10.90.231.0/26
	FREE	10.90.231.64/26
	europe-west2	10.90.231.128/26
	FREE	10.90.231.192/26
Prod	us-east4	10.90.247.0/26
	FREE	10.90.247.64/26
	europe-west2	10.90.247.128/26
	FREE	10.90.247.192/26
Dedicated (gcp-ih-dedicated)		
Environment	Region	CIDR
Nonprod	us-east4	10.90.232.0/24
	europe-west2	10.90.233.0/24

Prod	us-east4	10.90.248.0/24
	europa-west2	10.90.249.0/24
AEM (gcp-ih-aem)		
Environment	Region	CIDR
Nonprod	us-east4	10.90.234.0/24
	europa-west2	10.90.235.0/24
Prod	us-east4	10.90.250.0/24
	europa-west2	10.90.251.0/24
GSK.com (gcp-ih-gskdotcom)		
Environment	Region	CIDR
Nonprod	us-east4	10.90.236.0/26
	FREE	10.90.236.64/26
	europa-west2	10.90.236.128/26
	FREE	10.90.236.192/26
Prod	us-east4	10.90.252.0/26
	FREE	10.90.252.64/26
	europa-west2	10.90.252.128/26
	FREE	10.90.252.192/26
Remaining and unused IP addresses		
Environment	Region	IP addr space
Nonprod	FREE	10.90.224.1 - 10.90.224.254
	FREE	10.90.237.1 - 10.90.239.254
Prod	FREE	10.90.240.1 - 10.90.240.254
	FREE	10.90.253.1 - 10.90.255.254

2.2.2 Projects breakdown & shared VPCs

PROJECT_ID	NAME	DESCRIPTION
gsk-ih-aem-c227	IH AEM	Adobe Experience Manager stack - control plane
gsk-ih-aem-nonprod-068a	IH AEM nonprod	Adobe Experience Manager stack
gsk-ih-aem-prod-8527	IH AEM prod	Adobe Experience Manager stack
gsk-ih-apache-bc4d	IH Apache	Apache static & PHP stack - control plane
gsk-ih-apache-nonprod-2bde	IH Apache nonprod	Apache static & PHP stack
gsk-ih-apache-prod-b3b2	IH Apache prod	Apache static & PHP stack
gsk-ih-automation-images	IH Automation-Images	Project, where compute VM images are being build & storred
gsk-ih-backend-948f	IH Backend	Backed project for shared VPC - control plane
gsk-ih-backend-nonprod-12e8	IH Backend nonprod	Backed project for shared VPC
gsk-ih-backend-prod-4f82	IH Backend prod	Backed project for shared VPC
gsk-ih-dedicated-b82d	IH Dedicated	Resources for dedicated hosting environments - control plane
gsk-ih-dedicated-nonprod-b4b2	IH Dedicated nonprod	Resources for dedicated hosting environments

PROJECT_ID	NAME	DESCRIPTION
gsk-ih-dedicated-prod-62bf	IH Dedicated prod	Resources for dedicated hosting environments
gsk-ih-gskdotcom-b2db	IH GskDotCom	Corporate identity resources - control plane
gsk-ih-gskdotcom-nonprod-5563	IH GskDotCom nonprod	Corporate identity resources
gsk-ih-gskdotcom-prod-ec40	IH GskDotCom prod	Corporate identity resources
gsk-ih-iis-8c6d	IH IIS	IIS / .NET hosting env - control plane
gsk-ih-iis-nonprod-f0d1	IH IIS nonprod	IIS / .NET hosting env
gsk-ih-iis-prod-2aee	IH IIS prod	IIS / .NET hosting env
gsk-ih-j2ee-f79c	IH J2EE	J2EE hosting env - control plane
gsk-ih-j2ee-nonprod-372f	IH J2EE nonprod	J2EE hosting env
gsk-ih-j2ee-prod-a5e1	IH J2EE prod	J2EE hosting env
gsk-ih-serverless-79cc	IH Serverless	Serverless compute resources - control plane
gsk-ih-serverless-nonprod-c3f7	IH Serverless nonprod	Serverless compute resources
gsk-ih-serverless-prod-fb95	IH Serverless prod	Serverless compute resources

2.2.3 Compute VM / Instance group

Compute engine is Google's service which let customers build services consisting of virtual machines grouped in instance groups. All compute instances within the group are equal nodes of the cluster to process the traffic from customers through load balancer.

Virtual machines, which are compute entities used to set up instance groups, can be created/scaled dynamically in case of stateless servers (combined in managed instance groups) or created/scaled manually in case of stateful servers (managed or unmanaged instance groups).

List of workload modules used for constructing hosting environments:

Module name	Description
gcp-ih-aem-author-terraform	Adobe Experience Manager - Author instance
gcp-ih-aem-chef-server-terraform	Adobe Experience Manager - Chef instance
gcp-ih-aem-jenkins-terraform	Adobe Experience Manager - Jenkins instance
gcp-ih-aem-nexus-terraform	Adobe Experience Manager - Nexus instance
gcp-ih-aem-publisher-terraform	Adobe Experience Manager - Publisher instance
gcp-ih-apache-batch-server-terraform	Batch server for Apache stack
gcp-ih-apache-php-terraform	Apache-PHP hosting stack
gcp-ih-apache-rewrite-terraform	Apache-Rewrite hosting stack
gcp-ih-apache-static-terraform	Apache-Static hosting stack
gcp-ih-basic-stack-terraform	Basic stack for servers without loadbalancers
gcp-ih-brazil-vaccines-terraform	Custom stack for Brazil Vaccines
gcp-ih-c2c-terraform	Custom stack for Click2Chat
gcp-ih-docker-terraform	Docker hosting stack
gcp-ih-email-alias-terraform	Email alias server template

gcp-ih-email-relay-terraform	Email relay server template
gcp-ih-ext-jenkins-terraform	External Hosting Jenkins stack (for NodeJS management)
gcp-ih-fenistil-terraform	Custom stack for Click2Chat
gcp-ih-iis-batch-server-terraform	Batch server for IIS stack
gcp-ih-iis-static-terraform	IIS static hosting stack
gcp-ih-j2ee-jboss-terraform	J2EE Jboss/Tomcat hosting stack
gcp-ih-liferay-terraform	Custom stack for Liferay (gskpro.com/it)
gcp-ih-nordic-umbraco-terraform	Custom stack for Nordic Umbraco
gcp-ih-openvpn-terraform	OpenVPN gateway
gcp-ih-payer-portal-terraform	Custom stack for Payer Portal
gcp-ih-searchblox-terraform	Custom stack for SearchBlox
gcp-ih-stateful-workload-terraform	Basic stateful workload template
gcp-ih-stateless-workload-terraform	Basic stateless workload template
gcp-ih-tesaro-bio-terraform	Custom stack for Tesaro-BIO
gcp-ih-umbraco-corpcomms-terraform	Custom stack for CorpComms Umbraco

2.2.4 Cloud Load Balancing & Cloud Armor

Google Cloud HTTP(S) Load Balancing is a global, proxy-based Layer 7 load balancer that enables you to run and scale your services worldwide behind a single external IP address. External HTTP(S) Load Balancing distributes HTTP and HTTPS traffic to backends hosted on Compute Engine.

In case of GLB the address is multicast one. That means the traffic is directed to the nearest point-of-presence to be processed by Google Front End and then to be send to respective backend consisting of instance groups.

In addition to load balancing the traffic which pass through GLB is subject of scanning by Web Application Firewall (WAF) called Cloud Armor. Google Cloud Armor solution is based on implementation of OWASP TOP10 rules based on ModSecurity CoreRuleSet [5].

WAF rules tuning per load balancer is being done according to following process:

1. Rules to be enables in preview mode
2. Required exceptions to be identified during application testing or shortly after production deployment
3. Rules to be enabled in enforcing mode only when false-positive ratio in preview mode is acceptable

WAF logs must be monitored as part of regular platform maintenance activities as described in Service Design for Internet Hosting Service in GCP [6].

Google LoadBalancer is capable of proxying external origin (website/application hosted outside of GCP) within the domain hosted in GCP itself. This traffic is subject of the same security rules (WAF) as traffic to internal components.

External proxy capabilities within Internet Hosting environment are used for two scenarios:

- For applications hosted on external platforms (such as legacy platform in AWS),
- For dedicated hosting applications which are subject of full separation from main hosting platform.

2.2.5 Cloud Functions & Cloud Run

Cloud functions are means for running application code without necessity to provision and configure servers (so called server-less computing).

There are two variants provided:

1. Cloud Function
 - based on gcp-ih-cloud-functions-framework module
 - set up from code uploaded to cloud bucket
 - separate instance dynamically created for each request
2. Cloud Run
 - based on gcp-cloudrun-deployment-terraform
 - setup from docker container image from registry
 - instance capable for processing multiple requests

2.2.6 Logging & Monitoring

Cloud Logging is a fully managed service that performs at scale and can ingest application and system log data, as well as custom log data from GKE environments, VMs, and Google Cloud services.

Logging is configured at project and at organization level.

Logs are processed by Log Router[7] which filter the entries and send them to storing locations:

Log storage	Description	Data retention
log storage	Available by default for all projects,	_Required log bucket – 400 day, non-configurable _Default log bucket – 30 day, configurable, changed to 3 year
cloud storage	only for archival reasons, not used in IHS Platform at the moment	Depending on CloudStorage setup
big query	in case where additional processing is required, used in AEM projects only at the moment	3 year

There are two class of log messages:

1. _Required: include Admin Activity audit logs, System Event audit logs and Access Transparency logs [8]; default retention can't be changed, logs can't be disabled
2. _Default: includes any log entry that isn't ingested by the _Required log class, retention can be changed

Logging & monitoring services are available via Google's API and authorized via Service Accounts (explained in System Access Plan [9]).

Audit logs (includes _Required log class) are exported to GSK-managed SIEM system based on definition from module gcp-security-logs-export-terraform, module usage:

<https://mygithub.gsk.com/gsk-tech/gcp-cloudpharma-tech-terraform/blob/bffddecc65261be3de1219205175e480c850a2e9/security/security-logs-export.tf#L28-L38>.

2.2.7 Cloud SQL

Cloud SQL is fully managed relational database service for MySQL and SQL Server. Cloud SQL automatically ensures databases are reliable, secure, scalable and resilient . Cloud SQL automates all backups, replication, encryption patches, and capacity increases.

Databases to be created based on the following modules:

Module name	Description
gcp-cloudsql-mssql-terraform	Module to set up Microsoft SQL Server database instance, available versions: SQLSERVER_2017_STANDARD, SQLSERVER_2017_ENTERPRISE, SQLSERVER_2017_EXPRESS, SQLSERVER_2017_WEB
gcp-cloudsql-mysql-terraform	Module to set up MySQL database instance, available versions: MYSQL_5_6, MYSQL_5_7, MYSQL_8_0

Note the fact that Internet Hosting service is a platform for external facing application hosting and thus data management stored in these databases is the responsibility of the application owners as described in System Requirements for Internet Hosting in GCP [2].

2.2.8 NetApp

NetApp Cloud Volumes ONTAP is a software-defined storage offering that delivers advanced data management for file and block workloads.

ONTAP configuration to be managed by the following modules/resources:

Module/resource name	Description
gcp-netapp-networking-terraform	Module for managing NetAPP networking setup
gcp-netapp-iam-terraform	Module for managing NetAPP privileges setup
netapp_gcp_volume	Resource for NetAPP volumes configuration

ONTAP components are located within dedicated subnetworks and access to the fileshares is controlled on two levels:

- Access allow rules for shares on the ONTAP
- general firewall rules defined for VPC to limit traffic to the ONTAP components

Firewall policies for ONTAP traffic to be allowed:

Network	Protocol/ports	Source	Destination
Global-network	TCP/80,443	NetApp instances	0.0.0.0/0
ONTAP-vpc	All/all	Ontap-subnetwork	Ontap-subnetwork
Global-network	TCP/138,139,445 UDP/138/139/445	All subnetworks	NetApp instances
Global-network	TCP/63001, 63002, 63003, 63004	HealthCheck ranges	NetApp instances

Global-network	TCP/80, 111, 139, 161, 162, 443, 445, 635, 749, 2049, 3260, 4045, 4046, 10000, 11104, 11105 UDP/111, 161, 162, 635, 2049, 4045, 4046, 4049	All subnetworks	NetApp instances
----------------	---	-----------------	------------------

In terms of outbound traffic to the public internet the only allowed connections are to ports 80 & 443. This setup does not give the possibility for scanning the traffic but all firewall rules in cloudpharma.tech organization are mandated to log the connections so traffic is monitored. The forwarding-proxy-type functionality is being implemented as S-NAT router on the edge of the network.

2.2.9 VPNs / Routing / internet access via Cloud NAT

Google Cloud routes define the paths that network traffic takes from a virtual machine instance to other destinations. These destinations can be inside your Google Cloud Virtual Private Cloud (VPC) network or outside it.

Routing within GCP is designed in the way that all hosts within the same subnetwork or within different subnetworks communicate via the Cloud Router. This approach guarantee full (firewall) control over the traffic between Internet Hosting platform components.

Additional component related to VPN & routing is Google Cloud firewall, which is responsible for filtering the traffic between Compute VMs and other components connected to VPCs.

This approach guarantee:

- Network segmentation as resources are connected to networks dedicated for specific functions
- Full traceability over the network traffic as firewall rules are mandated to log the allowed/denied traffic

Firewall rules management is controlled by:

- Code review process which mandate peer review and approval prior to new rules are implemented,
- These compliance verification mechanisms (part of SCC) aim to identify inappropriate firewall rules (i.e. port 22 opened for 0.0.0.0/0)

Cloud VPN components enable connectivity between VPC networks and VPC / external networks.

Google Cloud VPN to be set up:

- Connectivity between GCP projects which do not share the same VPC
- Connectivity with legacy environment hosted in AWS
- Connectivity with GSK corporate network – there is stateful firewall set up for the connection which allows traffic to be initiated from Corpnets to GCP but not vice versa

Firewall rules to enable traffic through VPN channels are listed in section 2.2.10.

In addition to Google's Cloud VPN solution an OpenVPN-AS must be configured within the environment. This additional VPN is meant for non-GSK users non-privileged access only to limit exposure of interfaces for website content management (SFTP) to the public internet.

Firewall rules to enable traffic through OpenVPN-AS gateway are listed in section 2.2.10.

There are three layers of protection applied on the OpenVPN solution:

- OpenVPN firewall rules grant access to specified resources only, ie. to GSK.COM resources or to SFTP server for static websites,
- Individual account need to be created,
- general firewall rules are defined at VPC level to limit traffic between VPN components, including OpenVPN server – refer to section 2.2.10 for details.

2.2.10 Standard firewall configuration

Routing/firewall within GCP is designed in the way that all hosts within the same subnetwork or within different subnetworks communicate via Cloud Router.

Default firewall rule within IHS platform in GCP is to deny all traffic.

Having that approach there are open ports within the environment:

Protocol/Port	Description	Scope
TCP/80 & TCP/443	HTTP & HTTPS protocols	All servers to Internet, to access vendor's software repository
TCP/25, TCP/465, TCP/587	Email transfer	All servers to email-relay server, which stands as a bridge to Internet for email delivery
TCP/22	SSH/SFTP protocol	- from Jenkins/CICD servers to managed hosts - to batch server which hosts SFTP server, allowed from OpenVPN and GSK's corpnet - between GCP & legacy AWS components
TCP/3306, TCP/3307, TCP/1432	Database connectivity (MySQL & MSSQL respectively)	Allowed from servers to SQL Proxy resources
TCP/111, 2049, 635, 4045-4047 UDP/111, 2049, 635, 4045-4047	NFS connectivity	- from GCP servers to GCP NetApp components - from GCP servers to AWS NetApp components
TCP/139, 445, UDP/138, 139	NetBios/CIFS connectivity	- from GCP servers to GCP NetApp components - from GCP servers to AWS NetApp components

2.2.11 Identity Aware Proxy

Identity-Aware Proxy (IAP) is used to manage access to applications running in App Engine environment, Compute Engine, and GKE.

IAP establishes a central authorization layer for applications accessed by HTTPS, so an application-level access control model can be adopted instead of using network-level firewalls.

To use resources protected by IAP user must login to Google Cloud console so that the access is managed based on Google's identity.

Server login within IHS Platform is enforced to use IAP to authenticate users. The other resources may use IAP upon request.

2.2.12 Security Command Center

Security Command Centre is the canonical security and risk database for Google Cloud [10]. Security Command Centre is a risk dashboard and analytics system for surfacing, understanding, and remediating Google Cloud security and data risks across an organization.

Functionality of the Security Command Centre is meant to fulfil IHS Platform security management via regular compliance scanning and threat monitoring. Functionality includes:

- Security health analytics
- Web Security Scanner
- Identity and Access Management (IAM) analysis
- Event Health Detection
- Container Health Detection

Security Command Center & Web Application Firewall logs & findings are reviewed according to the process described in Service Design for Internet Hosting Service in GCP [6]. The target solution for findings review is to outsource responsibility for that to Incident Response Team. This fact is registered and tracked as RSK-27250630 IHS in GCP: insufficient process for Incident Response for IHS Platform in GCP.

2.3 Software stacks

Internet Hosting environment is build using Terraform tool based on the code stored in MyGitHub repositories.

There are three classes of repositories/modules used: root, workload and config.

2.3.1 Root modules

Root modules are for managing individual software stacks ie Apache or IIS. The module contains definition of the Compute resources together with all other components required by the stack (IAM, firewall, etc).

Module	description
<code>gsk-tech/gcp-ih-aem-terraform</code>	root module for Adobe Experience Manager stack for BioPharm

Module	description
gsk-tech/gcp-ih-apache-terraform	root module for Apache stack for BioPharm
gsk-tech/gcp-ih-dedicated-terraform	root module for dedicated environments for BioPharm
gsk-tech/gcp-ih-gskdotcom-terraform	root module for Corporate identity stack for BioPharm
gsk-tech/gcp-ih-iis-terraform	root module for IIS stack for BioPharm
gsk-tech/gcp-ih-j2ee-terraform	root module for J2EE stack for BioPharm
gsk-tech/gcp-ih-serverless-terraform	root module for serverless computing components for BioPharm

2.3.2 Workload modules

Workload modules are for managing configuration of individual class of Compute instances ie Apache-static or Apache-PHP. The module contains definition of compute resources, instance groups load balancers and all other components required for the stack to serve traffic to external users (IAM, firewall, etc).

Module	description
gsk-tech/gcp-ih-aem-author-terraform	module to provision AEM author instance group
gsk-tech/gcp-ih-aem-chef-server-terraform	module to provision AEM chef-server infrastructure
gsk-tech/gcp-ih-aem-jenkins-terraform	module to provision AEM Jenkins infrastructure
gsk-tech/gcp-ih-aem-nexus-terraform	module to provision AEM nexus infrastructure
gsk-tech/gcp-ih-aem-publisher-terraform	module to provision AEM publisher instance group
gsk-tech/gcp-ih-apache-php-terraform	module to provision Apache + PHP instance group
gsk-tech/gcp-ih-apache-static-terraform	module to provision Apache static instance group
gsk-tech/gcp-ih-email-alias-terraform	module to provision email-alias instance group
gsk-tech/gcp-ih-email-relay-terraform	module to provision email-relay instance group
gsk-tech/gcp-ih-ext-jenkins-terraform	module to provision External Hosting Jenkins infrastructure
gsk-tech/gcp-ih-iis-batch-server-terraform	module to provision windows batch server & infrastructure
gsk-tech/gcp-ih-iis-static-terraform	module to provision IIS .NET instance group
gsk-tech/gcp-ih-j2ee-jboss-terraform	module to provision Jboss J2EE instance group
gsk-tech/gcp-ih-openvpn-terraform	module to provision OpenVPN-AS instance group
gsk-tech/gcp-ih-searchblox-terraform	module to provision SearchBlox instance group
gsk-tech/gcp-ih-stateful-workload-terraform	module to provision stateful instance group
gsk-tech/gcp-ih-stateless-workload-terraform	module to provision stateless instance group

2.3.3 Config modules

Config modules are for managing configuration of the stateless workloads – the configuration stored in the modules is written to Cloud Storage after validation to be read by stateless module upon request.

Module	description
gsk-tech/gcp-ih-apache-jboss-configs	Apache-JBoss config for BioPharm
gsk-tech/gcp-ih-apache-php-configs	Apache-PHP config for BioPharm
gsk-tech/gcp-ih-apache-static-configs	Apache-Static config for BioPharm

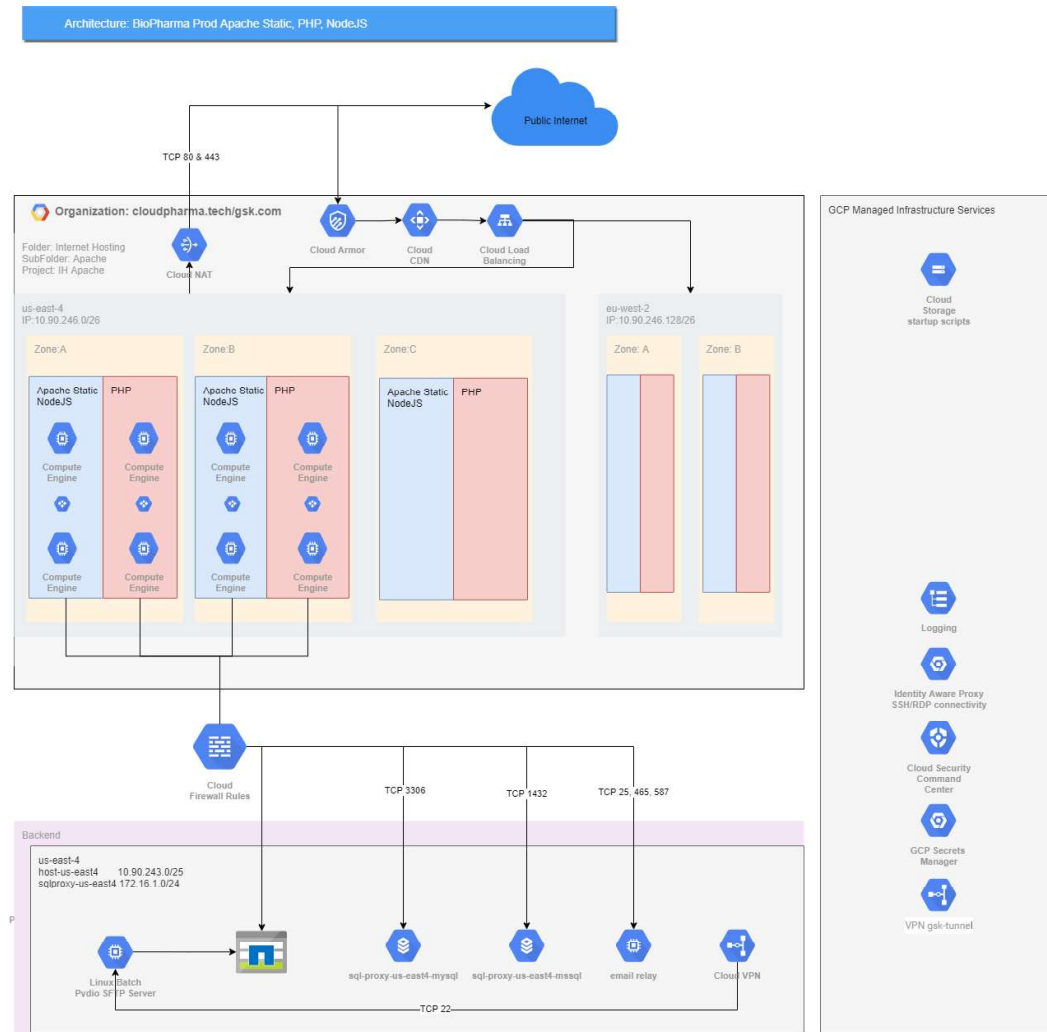
2.3.4 Stateless-managed hosting stack

Stateless-managed hosting stack is cluster of the servers set up for specific purpose ie hosting Apache-Static websites which does not keep any application state on them. Not keeping a state shall be understood that neither session nor database for the application are stored on the server and the application files to be executed are read from external repository or volume.

The below picture denotes Apache stateless hosting stacks in two variants:

- Blue one for Apache static hosting stack together with NodeJS applications
- Pink one for Apache-PHP hosting stack

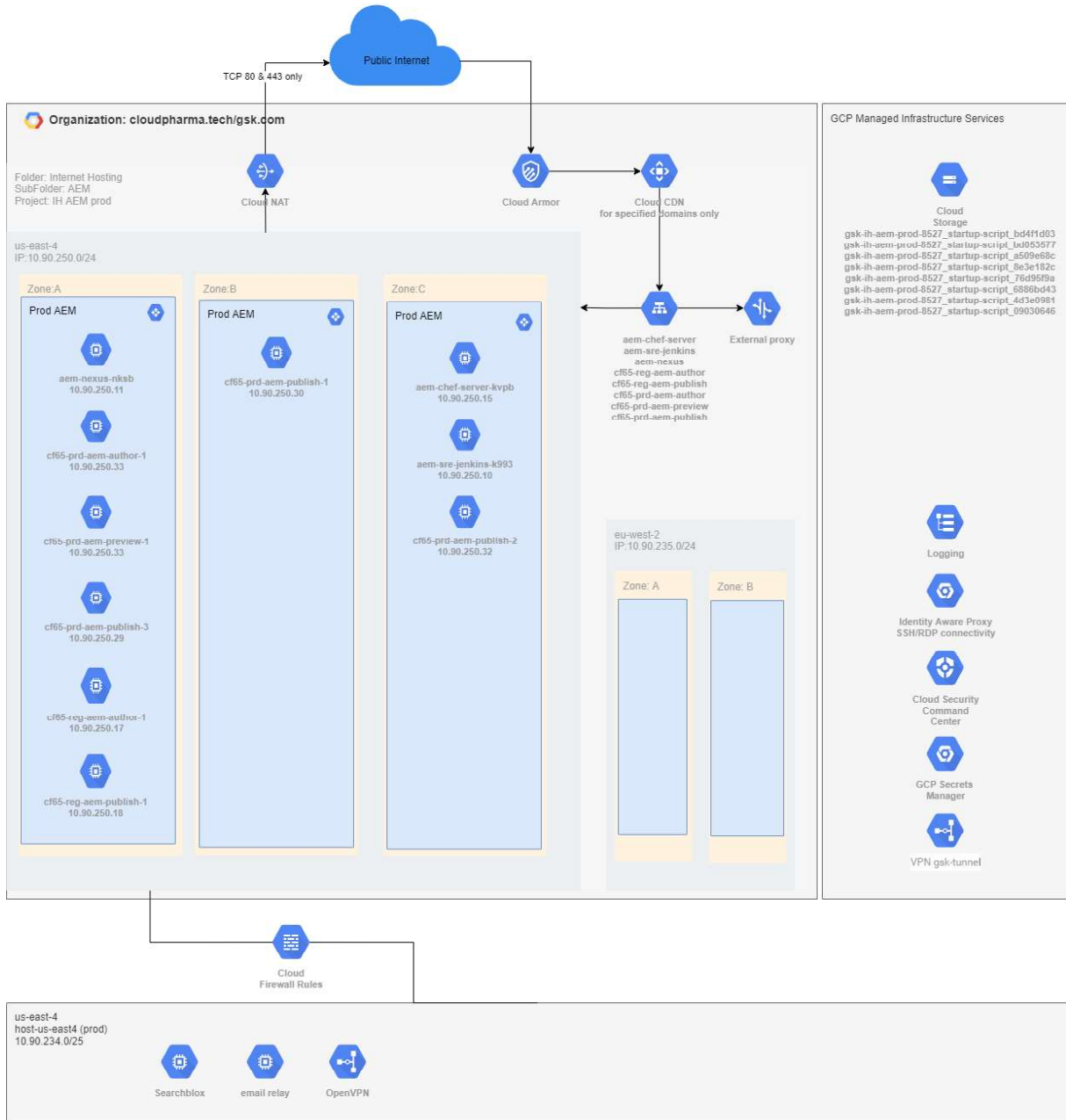
Each stateless stack is grouped within one Instance Group per region having compute VMs spread across zones for redundancy. Having resources within other regions require setting up another Instance Group within the region.



2.3.5 Stateful-unmanaged hosting stack

Stateful-unmanaged hosting stack is cluster of the servers set up for specific purpose i.e., hosting Adobe Experience Manager application which DOES KEEP application state on them. Keeping a state shall be understood that data required by the application to process the traffic from the customers are stored on the servers itself. Servers cannot be replaced without losing application data.

Architecture: BioPharma Prod AEM



2.3.6 CI/CD & stack management components

IHS platform provides the following components for dynamic stack management:

Module	description
gsk-tech/gcp-ih-aem-jenkins-terraform	Jenkins [11] automation server for AEM stack
gsk-tech/gcp-ih-ext-jenkins-terraform	Jenkins [11] automation server for NodeJS stack & for Serverless components
gsk-tech/gcp-ih-docker-terraform	Workload for hosting Docker [12] containers
gsk-tech/gcp-consul-cluster-terraform	Consul [13] workload for controlling ephemeral infrastructure components

2.4 Data

Internet Hosting Service provides environment for hosting Internet Facing applications but is not responsible for managing data within those applications. Data management is the responsibility of the application owner

2.5 System Operation Specification

There are two types of systems provisioned within IH environment: Linux and Windows. Linux servers are based on Ubuntu Linux 20.04 LTS, latest patch level. Windows servers are based on Windows 2019, latest patch level

Operating systems are installed from public images provided by GCP. Public images are maintained by GCP to have latest available patch level for specific OS. Based on that approach each stateless server can be rebuild regularly to use latest & greatest image available. This approach eliminate necessity of patching for stateless servers. Stateful servers however require regular maintenance in terms of patching.

2.6 Specific Areas of Design

2.6.1 Access Management

Access Management approach is described in System Access Plan for Internet Hosting Service [9].

There are two levels of access management:

- Formal access request process for non-privileged or privileged access as described in System Access Plan [9]
- Access for particular resources such as CloudFunction or Compute VM managed from code with approval from code owner/peer. Access can be granted only for the group, limitation set up on organization level.

Organization policies are listed within Cloud Enablement documentation: [2.7 Organisation Policies - Dreamforce Cloud Enablement - Confluence \(gsk.com\)](#).

2.6.2 System Security and Information Protection

Platform security is based on paradigm of least privileges ensured by:

- Default access to the GCP console does not give privileges for resource modification – ensured by default bootstrap configuration
- Extended access to modify resources is possible only after approval from infrastructure code owner AND only temporarily – ensured by peer review process

2.6.3 Password management

All secrets such as API keys, passwords, certificate keys, and other sensitive data used in Terraform code describing IHS Platform must be stored within Secret Manager. Secret Manager provides a central place and single source of truth to manage, access, and audit secrets across Google Cloud, which includes but is not limited to:

- granular access control for granting access to the secrets,
- secrets versioning, if an update is required,
- access audit for the secrets.

Operational assurance of Secrets Manager usage is supported by the peer review process for the code prior to release; the code review process is described in Service Design for Internet Hosting Service in GCP [6].

2.6.4 Audit Trail & logging strategy

Audit Trail functionality within Internet Hosting Service is based on log of changes within MyGitHub repositories. This approach is based on paradigm where all the changes shall be described in the appropriate code and approved by code owner prior to automatic deployment.

Logging strategy is based on two pillars:

- Logging configuration on project level
- Logging configuration on organization level.

Logging on project level by default store all events for 30 days and all audit events for 400 days.

General logging approach within cloudpharma.tech organization is described within Cloud Enablement team documentation:

<https://myconfluence.gsk.com/display/DREAMCE/4.5+Security+logs+export+from+GCP>.

The overall logging setup within cloudpharma.tech organization is managed within organization definition available on MyGitHub: <https://mygithub.gsk.com/gsk-tech/gcp->

[cloudpharma-tech-terraform/tree/master/security](https://github.com/gsk-tech/gcp-security-logs-export-terraform). Logging is configured via usage of module <https://mygithub.gsk.com/gsk-tech/gcp-security-logs-export-terraform>.

Audit logs collected through the above modules are to be shipped to central SIEM system via Pub/Sub topic [14]. The solution is out of scope of Internet Hosting Design hence no description within this document.

2.6.5 Electronic Signatures

There are no electronic signatures used in the Internet Hosting Platform in GCP.

2.6.6 Resilience and Continuity

Redundancy within the service is based on two pillars:

- Services which require availability greater or equal to 99,95% are located on redundant components such as compute instance groups (cluster of virtual machines)
- Access to the services is provided via load balancers (internal or external) to ensure backend components can be replaced when needed without impact on consumers of the service

Backup strategy within the service is based on snapshots of disks attached to the compute instances & netapp fileshares. Retention policy for the snapshots is 35 days as specified in GRS013 [15].

2.6.7 Network Security & segmentation

Network security is based on segmentation approach and default policy allowing only defined traffic. Additionally communication across servers within the same subnetwork needs to be explicitly allowed – this is the default GCP behaviour that all hosts within the subnetwork communicate through router.

Structure of the network is presented on the diagrams in section 2.1 of this document.

The basic rule for provisioning services are:

- VPC network and all the subnetworks are defined within backend project
- All software stacks like Apache static or AEM are segregated into separate subnetworks, additionally split into production and non-production subnetworks
- There is no incoming nor outgoing traffic allowed by default for the workload, with exception for ports 80 and 443 (http/https) which are required for maintenance activities such as patching
- Any traffic required to be enabled needs to be defined specifically using either network tags assigned to instances, instance's service accounts or specific addressed of the instance

It is responsibility of code developer and core owner/approver to follow the above rules.

Additionally all incoming external traffic is protected by Google Cloud Armor. Cloud Armor is Google's feature of load balancer which:

- Protect an application from volumetric attacks (DDoS)
- Mitigate risks defined in OWASP Top 10 using modsecurity rules (Web Application Firewall)

WAF rules are defined on workload level to allow tuning per-application (various application stacks require various rules).

2.6.8 Host System Security and Threat and Vulnerability Management

Host security is based on three main pillars:

- Intrusion Protection & Prevention ensured by usage of TrendMicro Deep Security on all of the servers within environment
- Security Command Centre within GCP, which scans configuration settings and identify misconfigurations or vulnerabilities
- OS component currency based on images delivered by Google along with OS vendors (Canonical for Ubuntu Linux & Microsoft for Windows)

Notifications from IP&P and SCC systems are sent to Teams channel/Service Now for actions to be taken.

OS component currency is ensured by

- Automatic OS image replace for stateless & stateful-managed workloads, OS image is being rebuild automatically every two weeks or upon request, fresh images are automatically being applied to stateless & stateful-managed workloads
- Manual patching activity for unmanaged workloads, Manual patching process is controlled by Ansible scripts managed in repository <https://mygithub.gsk.com/gsk-tech/gsk-internet-hosting-ansible-playbooks> Manual patching process must be proceed at least quarterly.

2.6.9 SSL Certificates management

An SSL (Secure Sockets Layer) certificate is a digital certificate that authenticates the identity of a website and encrypts information sent to the server using SSL technology. Every platform component which require SSL certificate must use:

- Certificate signed by Central GSK Certificates Portal [16]
- Domain Validation (DV) certificates that Google provisions, renews, and manages for domain names [17]

Usage of self-signed certificates is not allowed within IHS Platform.

2.6.10 Encryption at-rest

All IHS Platform data stored in Google Cloud are encrypted at rest, without any action required from the customer, using one or more encryption mechanisms [18].

Data for storage is split into chunks, and each chunk is encrypted with a unique data encryption key. These data encryption keys are stored with the data, encrypted with ("wrapped" by) key encryption keys that are exclusively stored and used inside Google's central Key Management Service. Google's Key Management Service is redundant and globally distributed.

All data stored in Google Cloud is encrypted at the storage level using AES256.

However possible to use own keys for managing encryption-at-rest in GCP Internet Hosting Service decided to rely on Google's managed keys following Google's encryption consent [19].

2.6.11 Other Risk-related Design Component

Cryptographic configuration within the platform adhere to the standards defined in Cryptographic Standard SOP-IT-0005[20]. The cryptographic configuration includes but is not limited to:

- SSL traffic encryption,
- Data encryption at rest,
- Secret Manager & ciphers stored in repository encryption.

2.7 Configuration management approach

Configuration management within Internet Hosting Platform is based on two pillars:

- Standard GSK's Change management process based on SOP-IT-0009 [21], change controls to be registered in Service Now system according to work instruction [22]
- Technical control of the changes via mandatory peer review enforced by MyGitHub repositories configuration and automatic change deployment via Terraform, based on code taken from protected repository branch.
No manual change for platform configuration is allowed by default, only manual modification is allowed after elevating privileges what is protected by two controls
 - o Elevated privileges can be granted only via terraform code thus are fully audited
 - o Elevated privileged require peer approval (as any other code) and are granted only temporarily (expire automatically after agreed date)

2.8 User Interface

No specific UI is provided for Internet Hosting Service. Activities are being done via interfaces provided by vendors and via standard interfaces for particular protocols.

3. References

Table 2 - References

No.	Identifier	Title
1.	SOP_00000306621	Specify System, SOP-IT-0032
2.	VQD-SPEC-066055	System Requirements for Internet Hosting in GCP
3.	n/a	https://cloud.google.com/vpc/docs/concepts
4.	n/a	https://cloud.google.com/compute/docs/regions-zones
5.	n/a	https://modsecurity.org/crs/
6.	VQD-SPEC-066054	Service Design for Internet Hosting Service in GCP
7.	n/a	https://cloud.google.com/logging/docs/routing/overview
8.	n/a	https://cloud.google.com/cloud-provider-access-management/access-transparency/docs/overview
9.	VQD-SOP-066572	System Access Plan for Internet Hosting Service in GCP
10.	n/a	https://cloud.google.com/security-command-center/docs/concepts-security-command-center-overview
11.	n/a	https://www.jenkins.io/
12.	n/a	https://www.docker.com/
13.	n/a	https://www.consul.io/
14.	n/a	https://cloud.google.com/pubsub/docs/overview
15.	n/a	Records Retention (gsk.com)
16.	n/a	GSK Certificates Portal
17.	n/a	https://cloud.google.com/load-balancing/docs/ssl-certificates/google-managed-certs
18.	n/a	https://cloud.google.com/security/encryption/default-encryption
19.	n/a	https://cloud.google.com/security/encryption/default-encryption#additional_encryption_options_for_cloud_customers
20.	VQD-STD-000387	Cryptographic Standard (STD-IT-0005)
21.	VQD-SOP-006195	Tech Change Management Procedure (SOP-IT-0009)
22.	VQD-WI-016424	Change Management Work Instruction for ServiceNow

4. Revision History

Table 3 – Revision History

Version	Date Author	Reason for Revision	Template Version Used
1.0	Refer to VQD Jaroslav Wencel	This is the first issue of this document	5.0
2.0	Refer to VQD Jaroslav Wencel	Editorial changes & template updates to version 6.0	6.0